CASE STUDY

Chrome Isolated Web Apps: Vulnerabilities and Abuse in 2026

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

Most people meet Chrome as a browser, but a growing number of organizations meet it as an application platform: kiosks, signage players, call-center clients and remote-desktop tools that run on managed Chromebooks. For apps that need more than a web page may safely have, such as raw network sockets or the ability to embed and script another website, Google built Isolated Web Apps (IWAs). An IWA is not served live from a web server. It is a bundle of files signed by the developer, identified by its signing key, installed like an app, and locked down with strict isolation headers, so that a compromised web server cannot push malicious code to every user (**Confirmed** [1] [2] [3]). In exchange for that packaging, Chrome lets an IWA use APIs it keeps away from the open web: Direct Sockets for raw TCP and UDP, and Controlled Frame for embedding and scripting arbitrary sites (**Confirmed** [1] [7] [8]).

This study set out to document a recent hack or exploit against IWAs. The honest answer from the primary record is that there is no known in-the-wild exploitation of IWAs. What 2026 does have is three separate stories. First, a steady stream of IWA bugs that Google found in its own code: ten CVEs in the IWA component and three more in the IWA-only Controlled Frame API, every one reported by Google, every one rated Medium or Low by Chromium, none in CISA's Known Exploited Vulnerabilities catalog (**Confirmed** [25] [31] [35] [39] [43] [45]; **Inferred** for the combined count). Second, offensive research: Praetorian in 2025 and SpecterOps in August 2026 published tools that sideload an IWA into a Chrome profile on Windows and use its Direct Sockets access as a SOCKS proxy for command and control (**Demonstrated** [68] [72]). Third, a year of genuine Chrome zero-days, eight of them in KEV, none of them in IWA code (**Confirmed** [45]).

The exposure is narrow but real. As of 11 November 2026 IWAs are switched on by default only on ChromeOS, desktop force-install is still marked for the future in Chromium's policy definitions, and Google's admin help says IWAs are supported only on ChromeOS (**Confirmed** [9] [11] [59]). On the fleets where they do run, several defaults are permissive: user installs are allowed unless an admin turns them off, and Direct

Sockets and Controlled Frame are allowed for IWA origins unless an admin blocks them (**Confirmed** [12] [13] [14]). The research shows that "off by default on desktop" does not stop someone who already runs code as the user, because the tools switch the feature on in the profile themselves (**Demonstrated** [68]; **Inferred** for the conclusion).

> Evidence grade: IWA design, policies, release dates, CVE descriptions and the KEV record are **Confirmed** from Google and Chromium documentation, Chromium source, Chrome Releases, NVD, the CVE List and CISA. The offensive tooling is **Demonstrated** by the researchers who published it and was not reproduced for this study. Threat-intelligence attributions for the non-IWA Chrome zero-days and trade-press counts are **Reported**. This study's own conclusions are labelled **Inferred**.

Key facts at a glance

Field	Value
What an IWA is	An isolated, bundled, versioned, signed application model on the web platform, for apps whose APIs cannot be made safe for the open web [1]
Identity	The app's origin, `isolated-app://<Web Bundle ID>/`, is derived from the developer's signing public key; Ed25519 or ECDSA P-256 [1] [3] [4]
Gated APIs	Direct Sockets (raw TCP, UDP, server sockets) and Controlled Frame (embed, script and intercept any site); sub apps and unframed windows from Chrome 152 [7] [8] [22]
Where IWAs run (11 Nov 2026)	Enabled by default only on ChromeOS in Chromium main; desktop force-install policy is `future_on`; Google admin help: "supported only on ChromeOS" [9] [11] [59]
Gatekeeping	Google allowlist for admin-installed IWAs from Chrome 143; a Google-distributed key distribution component; a bundle blocklist checked on every install path [18] [19] [20]
2026 CVE record	Ten CVEs in the IWA component (labelled "Isolated Web Apps" or "Isolated") and three in Controlled Frame; all reported by Google; all Medium or Low per Chromium [25] [31] [35] [39] [43] [49]
Highest score	CVE-2026-11102: Chromium Medium, NVD and CISA-ADP CVSS 3.1 8.8 High; its public Chromium issue describes a key-rotation bypass [26] [28]
Exploitation	No IWA or Controlled Frame CVE in KEV (catalog 2026.11.10); CISA-ADP SSVC "exploitation: none" on every record; no "exploit in the wild" line from Google [45] [38] [49] [50]
Exploited Chrome zero-days in 2026 (contrast)	Eight in KEV, in CSS, Skia, V8 (four), Dawn and XML; none in IWA code [45]
Offensive research	Praetorian ChromeAlone (DEF CON 33, Aug 2025) and SpecterOps SilentChrome-BOF and Ditto (13 Aug 2026): a sideloaded IWA uses Direct Sockets as a SOCKS bridge; SpecterOps's tools need prior code execution as the user on Windows [68]; ChromeAlone ships PowerShell sideloaders for Windows 10 and 11, which implies the same (Inferred) [72]
Build that carries every 2026 IWA fix	Chrome 157.0.8103.38 (Linux), .38/.39 (Windows, Mac); 157.0.8103.50 (Linux), .50/.51 (Windows, Mac) also fixes the latest KEV zero-day (Inferred: later milestones include earlier fixes) [43] [52]

Key findings

- **No IWA vulnerability has an in-the-wild record.** None of the thirteen IWA and Controlled Frame CVEs of 2026 is in KEV, Google attached its "exploit exists in the wild" line to none of them, and CISA's SSVC entry on each says exploitation none (**Confirmed** [45] [43] [39]; **Demonstrated** for the check [45]).
- **Every IWA bug was found by Google itself.** All ten IWA-component CVEs and the three Controlled Frame CVEs credit Google as reporter, and Chromium rated them Medium or Low (**Confirmed** [25] [31] [35] [39] [43]; **Demonstrated** [50] for the reporter of CVE-2026-17743 and the severity of CVE-2026-87435).
- **The severity scales disagree.** CVE-2026-11102 is Medium to Chromium and 8.8 High to NVD and CISA-ADP; every IWA bug Chromium calls Low gets a CVSS Medium from CISA-ADP (**Confirmed** [26] [34] [38]; **Inferred** for the cause).
- **Half the record hides from a keyword search.** From September Chrome Releases labels the component "Isolated" rather than "Isolated Web Apps", so an NVD search for "Isolated Web Apps" returns five of the ten (**Confirmed** [44] [39] [40]).
- **The public issue titles describe the trust machinery.** Key rotation, the mandatory CSP, cross-app navigation checks and sandbox origin rules are the subjects of the public Chromium issues, which is where the IWA security model concentrates its trust (**Confirmed** [28] [33] [37] [40] [41] [42]; **Inferred** for the reading).
- **The abuse that exists is post-exploitation persistence, built by researchers.** SpecterOps's tools reconstruct an installed IWA from profile files, grant it Direct Sockets through a locally registered key distribution component, and use it as a network sidecar for an extension-based agent (**Demonstrated** [68]); Praetorian's ChromeAlone sideloads an IWA, BLOWTORCH, that uses Direct Sockets as a SOCKS proxy (**Demonstrated** [72]). No vendor disclosure, CVE or fix is named for the technique (**Inferred** [68]).
- **The control plane is the defense.** Google's allowlist, blocklist and key distribution, and the admin's policies for user installs, Direct Sockets, Controlled Frame and DevTools, decide whether an IWA can exist on a device and what it can reach (**Confirmed** [12] [13] [14] [17] [18] [20]).
- **Desktop support keeps slipping.** Google's enterprise release notes have moved the target for Windows enterprise-managed IWAs from Chrome 140 to 146, 150 and then 161 (**Confirmed** [60]).

Top recommendations

1. **Decide whether your ChromeOS fleet should run IWAs at all.** If not, set `IsolatedWebAppUserInstallationEnabled` to false; it defaults to true from ChromeOS 146, and ChromeOS 150 lets users install IWAs by hand (**Confirmed** [12] [60]).
2. **Block the high-trust APIs by default and allow them per app.** Set `DefaultDirectSocketsSetting` and `DefaultControlledFrameSetting` to 2, then list the IWAs that need them in the matching `AllowedForUrls` policies, which accept only `isolated-app` patterns (**Confirmed** [13] [14] [15]).
3. **Inventory every force-installed IWA.** Check each one's `pinned_version`, which freezes it below later fixes, and its allowlist status, since an IWA dropped from Google's allowlist keeps running without updates (**Confirmed** [11] [20]; **Inferred** for the risk).
4. **Keep Chrome current and relaunched.** The 2026 IWA fixes ship in ordinary Chrome milestones; `RelaunchNotification` and `RelaunchFastIfOutdated` shorten the gap between download and restart

(**Confirmed** [43] [66] [67]).

5. **Close the developer doors.** Setting `DeveloperToolsAvailability` to Disallowed also disables IWA developer-mode installs, and disallowing Developer Mode for extensions stopped SpecterOps's unpacked extension from starting (**Confirmed** [17]; **Demonstrated** [68]).
6. **Watch for the profile tampering the research uses.** On Windows desktops, file writes to the browser's preference files, registry writes under the native messaging keys, and Chrome processes started with IWA launch arguments are cheap detections because legitimate IWA use on desktop is rare (**Demonstrated** [68]).
7. **Prioritize by exploitation, not by product name.** The Chrome bugs exploited in 2026 were in V8, Skia, Dawn, CSS and XML; KEV, not an IWA headline, should drive emergency browser patching (**Confirmed** [45]).

Scope and method

This study covers Chrome Isolated Web Apps from the design record to 11 November 2026: what IWAs are and where they run, the enterprise policies and Google allowlist that govern them, every 2026 CVE found in the IWA component and in the IWA-only Controlled Frame API, the public offensive research that abuses IWAs, the year's exploited Chrome zero-days as a contrast, and the defender's options. It draws on Google's Chrome for Developers and ChromeOS documentation, the WICG explainers, Chromium source and policy definitions read through the GitHub mirror at main, Chrome Releases posts, the public Chromium issue tracker, NVD, the CVE List, the CISA KEV catalog, Google's enterprise help pages, the SpecterOps and Praetorian research and repositories, Volexity, Microsoft and trade-press reporting on the 2026 Chrome zero-days, and the library's own MITRE data files. The Intelligence Hub feed was checked as a starting index; it has no row about Isolated Web Apps (**Confirmed** [79]). Every source was opened on 11 November 2026. Quotations are kept to a few words.

Grade	Meaning
Confirmed	A primary source was opened: the party's own record (Google or Chromium documentation, Chromium source, a Chrome Releases post, a Chromium issue, an NVD or CVE record, the CISA KEV catalog, a repository's own metadata)
Reported	Known only through a secondary source (press, a distribution's bug tracker, a vendor CVE page, a conference listing), or a threat-intelligence firm's attribution, attributed by name
Demonstrated	Shown working rather than asserted: a researcher's published proof of concept, attributed to that researcher and not reproduced here, or a count or search run against a primary dataset that anyone can repeat
Inferred	This study's own reasoning from the cited facts, labelled where it appears

Tradecraft is described at the level the advisories and the researchers' prose use: technique names and ids. No commands, flags, payloads, key material or file contents from the research tools are reproduced. Chromium issue titles are quoted because they are the public primary record of each fix. Where NVD and Chrome Releases give different fixed builds, this study cites the per-platform build in the release post. "IWA" means Isolated Web App throughout; Chrome's separate "Isolated Mode", an enterprise ephemeral browsing mode governed by the `IsolatedModeSettings` policy, is unrelated (**Confirmed** [24]).

Part 1: what an Isolated Web App is

The problem it solves

The WICG explainer aims IWAs at apps where a compromised main application server, serving malicious content, is a real threat, and at user agents that require this model before they grant APIs such as Direct Sockets. It says plainly that IWAs are not a good default for most web apps (**Confirmed** [2]). Chrome for Developers describes the model as isolated, bundled, versioned, signed and trusted, meant for apps whose APIs cannot be made safe for the open web (**Confirmed** [1]). Google's introduction says Direct Sockets and Controlled Frame cannot be made safe for the drive-by web (**Confirmed** [1]).

Packaging and signing

An IWA ships as a Web Bundle signed by the developer instead of being served live over HTTPS. The signing key can stay offline. An update is a new bundle signed with the same key, and implementations may check a version or timestamp to refuse downgrades (**Confirmed** [2]). Bundles are `.swbn` files and can be installed offline (**Confirmed** [1]).

A Signed Web Bundle puts a CBOR integrity block in front of the bundle. The signature covers the bundle's SHA-512 hash, the integrity block with its signature list emptied, and the signature attributes. The supported key types are Ed25519 and ECDSA P-256 with SHA-256, and at least one known signature must verify (**Confirmed** [3]).

Identity is the key

IWA URLs use the scheme `isolated-app://<signed-web-bundle-id>/`. The host is a lowercase, unpadded base32 encoding of the public key plus a type suffix, 56 characters for Ed25519. Port and credentials are always null, the URLs are secure contexts, and the user agent checks the signature and whether it trusts the key before loading (**Confirmed** [4]). Because the origin derives from the Web Bundle ID, which derives from the public key, each app needs its own key (**Confirmed** [1]). Google's admin help describes the ID as 56 or 58 base32 characters (**Confirmed** [59]).

That binding has a cost Google has written about. A compromised signing key is "a troublesome situation" in Google's words, and rebinding an app to a new key is planned only as a last resort (**Confirmed** [62], a design record from 8 October 2024, not an incident).

Isolation

Every IWA must send COOP `same-origin`, COEP `require-corp`, CORP `same-origin` and CSP `frame-ancestors 'self'`. A strict Content Security Policy limits scripts to the bundle and sets `object-src` and `base-uri` to none (**Confirmed** [5]). The explainer also requires Trusted Types and blocks cross-origin navigations into the app, to prevent sequence-breaking attacks (**Confirmed** [2]). Navigation is limited to the app's declared entry points (**Confirmed** [1]). Chromium gives each IWA origin its own storage partition (**Confirmed** [19]).

Permissions

Chrome docs say IWAs block all permission requests by default. An app opts in through the manifest's `permissions_policy` field, and only permissions declared in both the manifest and the bundle's headers are allowed (**Confirmed** [5]). Declaring a permission makes it requestable, not granted (**Confirmed** [1]). The permissions proposal changes the default allowlist to none and intersects the manifest with the `Permissions-Policy` header while still requiring user consent; a permitted iframe can delegate a permission to its own embedded content (**Confirmed** [6]).

The high-trust APIs

API	What it gives an IWA	Gate	Source
Direct Sockets	`TCPSocket`, `UDPSocket` and `TCPServerSocket`, for protocols such as SSH, RDP, printers and IoT	IWAs only (planned); the `direct-sockets` permissions policy, default self; enterprise policy can restrict it	[8]
Controlled Frame	Embedding content that refuses framing, injecting script, intercepting requests and permission prompts, capturing the visible region	IWAs only; the `controlledframe` permissions policy	[7]
Sub apps (Chrome 152)	Several apps under one IWA installation, controllable by policy	Admin policy	[22] [16]
Unframed display mode (Chrome 152)	The IWA fills the whole window	Not checked	[22]

The Controlled Frame explainer is candid about what the API can do. It warns that the embedding IWA could observe browsing activity, keystrokes and cookies inside the frame and could hijack file uploads (**Confirmed** [7]). chromestatus lists more IWA-gated work in the pipeline: a Window Shape API proposed for M154 on ChromeOS for allowlisted IWAs, the replacement of `direct-sockets-private` with the local-network and loopback-network permission policies at M151, `WebRequest.SecurityInfo` in Controlled Frame at M145, and Additional Windowing Controls in developer trial at M155 (**Confirmed** [23]).

Where IWAs ship

Google states that the initial release is limited to Chrome Enterprise administered ChromeOS devices and select development partners, with unmanaged and cross-platform support planned and no timeline; testing needs Chrome or ChromeOS 120 or later with the developer-mode flag (**Confirmed** [1]). The source code agrees. In Chromium main on 11 November 2026, the `kIsolatedWebApps` feature is enabled by default only on ChromeOS, `kIsolatedWebAppDevMode` is disabled by default, and `kIsolatedWebAppUnmanagedInstall` is enabled by default only on ChromeOS (**Confirmed** [9] [10]). Google's admin help says IWAs are supported only on ChromeOS, from ChromeOS 128 for users and browsers, 134 for kiosks and 140 for managed guest sessions; its Windows, Mac and Linux sections cover only ordinary web apps (**Confirmed** [59]).

Desktop is coming, slowly. Google's enterprise release notes have repeatedly announced support for IWAs in enterprise-managed browser configurations on Windows, with the target moving from Chrome 140 to 146, then 150, then 161 (**Confirmed** [60]). Which release's notes carried each target (140 in the Chrome 138 notes, 146 in 141, 150 in 147, 161 in 151) is a positional reading of the page (**Inferred** [60]).

Who decides what is trusted

The model moves trust away from the live web server and onto three other things: the developer's offline signing key, the host that serves the update manifest, and Google's allowlist and key distribution (**Inferred** [2] [19] [20]). Chrome ships a preloaded IWA Key Distribution component, kept current by the Component Updater, that carries key rotations, special permissions and access-control rules; IWAs update atomically once their windows close (**Confirmed** [19]). Chromium's trust checker requires policy-installed IWAs to be on Google's managed allowlist and listed in `IsolatedWebAppInstallForceList` (ChromeOS has a bypass flag), requires user installs to be on a user-install allowlist, confines kiosk IWAs to their kiosk session, and checks every path, developer mode included, against a bundle blocklist (**Confirmed** [18], file last changed 9 October 2026). Google's troubleshooting guidance says an installed IWA can go missing or show as damaged because its signing key was rotated or its app ID was blocked (**Confirmed** [59]).

Part 2: the control plane

The allowlist

From Chrome 143, only IWAs on Google's allowlist can be installed or updated through the Admin Panel, starting with ChromeOS; other operating systems adopt the restriction from their first IWA support (**Confirmed** [20]). The allowlist governs `IsolatedWebAppInstallForceList` for managed user and guest sessions and `DeviceLocalAccounts` for kiosks (**Confirmed** [20]). Non-allowlisted apps already installed keep running but stop updating, and Developer Mode is exempt: unlisted IWAs can still be installed through `chrome://web-app-internals` once the developer-mode flag is on (**Confirmed** [20]). Getting listed requires a Google partner contact, membership in the early adopter program and acceptance of an acceptable use policy; Google reviews requests within two business weeks, and approval covers every version of the app (**Confirmed** [20]).

A blink-dev public service announcement posted on 27 October 2025 announced the managed-installation allowlist for M143, covering ChromeOS and, once managed IWAs launch there, Windows, Mac and Linux. Its stated reasons are platform security and stability and a verified contact for security vulnerabilities (**Confirmed** [21]). Google's allowlist page names stability, trusted contact channels for key rotation, and acceptable use (**Confirmed** [20]). The calendar date Chrome 143 reached stable was not checked.

Google's IWA developer policy, last updated 13 January 2026, forbids using Direct Sockets to scan or attack local network devices, shipping interpreters to run downloaded code, and building Controlled Frame pass-throughs that proxy privileged access (**Confirmed** [63]).

The policies

Policy	Supported on	Default	Effect	Source
`IsolatedWebAppInstallForceList`	ChromeOS 128+; desktop `future_on`	Unset	Force-installs IWAs by `web_bundle_id` and `update_manifest_url`; optional `update_channel`, `pinned_version` and `allow_downgrades` (downgrades need a pin). Its description still says it works for Managed Guest Session only, which Google's admin help contradicts (Inferred)	[11] [59]
`IsolatedWebAppUserInstallationEnabled`	ChromeOS 146+ (added 10 Feb 2026)	True	False blocks users from installing IWAs by hand	[12]
`DefaultDirectSocketsSetting`	ChromeOS 131+; desktop `future_on`	Allow (1 or unset)	2 blocks Direct Sockets for IWA origins; `DirectSocketsAllowedForUrls` and `DirectSocketsBlockedForUrls` take only `isolated-app` patterns, and `*` is not accepted	[13]
`DefaultControlledFrameSetting`	ChromeOS 134+; desktop `future_on`	Allow (1 or unset)	2 blocks Controlled Frame; `ControlledFrameAllowedForUrls` and `ControlledFrameBlockedForUrls` take only IWA patterns, no wildcard	[14] [15]
`DefaultSubAppsWithoutPromptsSetting`	ChromeOS 150+	Ask (3)	1 lets IWAs add sub apps without a gesture or prompt; 2 blocks; per-origin overrides exist	[16]
`DeveloperToolsAvailability`	Not checked	Not checked	When Disallowed, IWA developer mode is disabled; otherwise developer mode needs the `kIsolatedWebAppDevMode` flag	[17]
`ExtensionSettings`, `ExtensionInstallAllowlist`, `ExtensionInstallBlocklist`	Chrome and ChromeOS 62+ and 86+; Android 146+	Policy-defined	Extension governance, relevant because the published IWA abuse pairs an IWA with an extension	[64]

Admins add an IWA in the Admin console by Web Bundle ID and update-manifest URL, and can force install it, force install and pin it, or prevent installation, and auto-grant some permissions; devices check for updates every 4 to 6 hours (**Confirmed** [5] [1]). Admin pinning and downgrades are available from Chrome 133, and channel selection for user-installed IWAs from Chrome 150 (**Confirmed** [61]). Admins can confirm on `chrome://policy` that `IsolatedWebAppInstallForceList` shows OK (**Confirmed** [59]).

Read together, the defaults matter more than any single CVE. On a managed ChromeOS fleet where IWAs are on, users may install IWAs unless an admin says otherwise, and any installed IWA may use Direct Sockets and Controlled Frame unless an admin blocks them (**Inferred** from [12] [13] [14]).

Part 3: the 2026 vulnerability record

Ten CVEs in the IWA component

CVE	Chromium label and severity	What NVD says it allowed	Public Chromium issue title	Reported by Google	Fixed in (Chrome Releases)	CVSS 3.1 (scorer)	CWE (CISA-ADP)
CVE-2026-11102	Inappropriate implementation in Isolated Web Apps; Medium	Code execution inside a sandbox via a malicious file	"Potential IWA Key Rotation Bypass via Unconditional Acceptance of Compromised Previous Key"	7 Apr 2026	Chrome 149, 2 Jun 2026: 149.0.7827.53 Linux, .53/.54 Windows, Mac	8.8 High (NVD and CISA-ADP)	CWE-474 (NVD: noinfo)
CVE-2026-13886	Policy bypass in Isolated Web Apps; Medium	Content Security Policy bypass via a crafted HTML page	"Bypass of mandatory IWA CSP via Service Worker navigation interception"	7 Apr 2026	Chrome 150, 30 Jun 2026: 150.0.7871.46 Linux, .46/.47 Windows, Mac	6.5 Medium (CISA-ADP)	CWE-693
CVE-2026-14042	Inappropriate implementation in Isolated Web Apps; Low	UI spoofing via a crafted HTML page	Restricted (issue 497558336)	29 Mar 2026	Chrome 150, 30 Jun 2026	4.3 Medium (CISA-ADP)	CWE-451
CVE-2026-17780	Inappropriate implementation in Isolated Web Apps; Medium	Bypass of navigation restrictions via a crafted HTML page	"Potential bypass of cross-IWA source check via Service Worker clients.openWindow()"	15 May 2026	Chrome 151, 29 Jul 2026: 151.0.7922.71 Linux, .71/.72 Windows, Mac	6.3 Medium (CISA-ADP)	CWE-284
CVE-2026-17909	Insufficient validation of untrusted input in Isolated Web Apps; Low	Cross-origin data leak via malicious network traffic	Restricted (issue 501693236)	11 Apr 2026	Chrome 151, 29 Jul 2026	5.3 Medium (CISA-ADP; no user interaction)	CWE-20
CVE-2026-87577	Incorrect authorization in Isolated; Medium	Web origin policy bypass into a privileged page	"IWA sandbox bypass via data: URL iframe precursor-collapse"	11 Apr 2026	Chrome 153, 8 Sep 2026: 153.0.8010.36 Linux, .36/.37 Windows, Mac	4.3 Medium (CISA-ADP)	CWE-863
CVE-2026-87540	Incorrect authorization in Isolated; Medium	UI element spoofing	"Potential IWA warning quota exhaustion via initiator fallback scope extension mismatch"	29 May 2026	Chrome 153, 8 Sep 2026	5.4 Medium (NVD and CISA-ADP)	CWE-863
CVE-2026-87468	Incorrect authorization in Isolated; Medium	Site isolation bypass via a crafted HTML page	"Bypass of cross-IWA navigation restrictions via WindowOpenDisposition:: NEW_POPUP"	9 Jul 2026	Chrome 153, 8 Sep 2026	6.5 Medium (CISA-ADP)	CWE-863
CVE-2026-121172	Incorrect authorization in Isolated; Low	UI spoofing	Restricted (issue 553270515)	27 Aug 2026	Chrome 157, 3 Nov 2026: 157.0.8103.38 Linux, .38/.39 Windows, Mac	5.4 Medium (CISA-ADP)	CWE-863
CVE-2026-121206	UI misrepresentation in Isolated; Low	Spoofing with social engineering	Restricted (issue 553289241)	27 Aug 2026	Chrome 157, 3 Nov 2026	5.4 Medium (CISA-ADP)	CWE-451

Sources by row: CVE-2026-11102 (**Confirmed** [25] [26] [27] [28] [48]); CVE-2026-13886 (**Confirmed** [31] [32] [33]); CVE-2026-14042 (**Confirmed** [31] [34]); CVE-2026-17780 (**Confirmed** [35] [36] [37]); CVE-2026-17909 (**Confirmed** [35] [38]); CVE-2026-87577, -87540 and -87468 (**Confirmed** [39] [40] [41] [42]); CVE-2026-121172 and -121206 (**Confirmed** [43]). NVD published CVE-2026-11102 on 4 June 2026,

CVE-2026-13886 and CVE-2026-14042 on 30 June, and CVE-2026-17780 and CVE-2026-17909 on 30 July (**Confirmed** [26] [32] [34] [36] [38]).

The two November CVEs, CVE-2026-121172 and CVE-2026-121206, sit in the component Chrome Releases calls "Isolated", but their Chromium issues are restricted, so linking them to IWAs rests on the component label alone (**Confirmed** for the label [43]; **Inferred** for the IWA link). The September issues remove most of the doubt about that label: the public issue for CVE-2026-87577 is filed under the component `UI>Browser>WebAppInstalls>Isolated` with an IWA title, and the issues for CVE-2026-87540 and CVE-2026-87468 carry the same component (**Confirmed** [40] [41] [42]). The September issues also carry an extended-stable merge label, 0-M156-EXT, besides 0-M153 (**Confirmed** [40] [41] [42]).

Three more in Controlled Frame

Controlled Frame is available only to IWAs, so its bugs belong in the same record (**Confirmed** [7]; **Inferred** for the grouping).

CVE	What the record says	Fixed in (Chrome Releases)	Score and SSVC	Source
CVE-2026-17743	Same-origin-policy bypass in ControlledFrame; Medium	Chrome 151, 29 Jul 2026: 151.0.7922.71 Linux, .71/.72 Windows, Mac	6.5; exploitation none	[35]
CVE-2026-87513	Missing authorization in ControlledFrame that let a remote attacker using social engineering bypass system access restrictions; Medium; reported by Google	Chrome 153.0.8010.36	6.5; exploitation none	[39] [49]
CVE-2026-87435	Information leak in ControlledFrame; reported by Google	Chrome 153.0.8010.36	No in-the-wild statement	[39]

(**Confirmed** for each row from the cited release post, and for CVE-2026-87513 from its CVE record [49].)

How many is the record?

Two independent sweeps were run and they count differently because they asked different questions. One counted CVEs in the IWA component across Chrome Releases, NVD and the Chromium tracker, and found ten (**Confirmed** [44] [39] [43]). The other searched the CVE List for "Isolated Web App" and "Controlled Frame" and found five IWA records plus three Controlled Frame records, eight in all, noting that code search can miss records, so eight is a count found, not a proven total (**Demonstrated** [50]). The union is thirteen: the ten IWA-component CVEs plus the three Controlled Frame CVEs (**Inferred**). An exact NVD keyword search for "Isolated Web Apps" returns five CVEs, all from 2026, none in KEV; searches for "Controlled Frame" and "Direct Sockets" return none (**Confirmed** [44]). The September and November entries say only "Isolated", which is why the keyword search misses them (**Confirmed** [44] [39] [43]).

For scale, the three Chrome milestones that fixed the first five IWA bugs listed 429, 433 and 371 security fixes in their release posts (**Confirmed** [25] [31] [35]). IWA is a small slice of Chrome's security work, and all of it was found internally (**Inferred**).

The severity disagreement

CVE-2026-11102 is the outlier. Chromium rates it Medium. NVD, the primary scorer, and CISA-ADP both give it CVSS 3.1 8.8 High with the vector AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H, and CISA-ADP's SSVC records technical impact "total", the only IWA CVE that gets it (**Confirmed** [26] [27] [48]). Red Hat's Bugzilla rates it Medium, agreeing with Chromium (**Reported** [29]). Tenable's CVE page shows 8.8 High, a CVSS v2 score of 10.0 Critical, and an EPSS of 0.00371 (**Reported** [30]).

The two descriptions of the same bug also differ. NVD says a remote attacker could execute arbitrary code inside a sandbox via a malicious file. The public Chromium issue is titled as a potential key rotation bypass through unconditional acceptance of a compromised previous key (**Confirmed** [26] [28]). The record does not explain how one becomes the other, and this study does not guess (**Inferred**). What the issue title does show is that the bug touched the mechanism Google relies on when a developer's signing key is compromised, the case Google itself calls troublesome (**Confirmed** [28] [62]; **Inferred** for the connection).

The rest of the gap is systematic. Every IWA CVE that Chromium rates Low (CVE-2026-14042, -17909, -121172 and -121206) receives a CVSS Medium of 4.3 to 5.4 from CISA-ADP, because CVSS 3.1 gives a network bug with low attack complexity, no privileges and user interaction at least 4.3, the bottom of the Medium band, as soon as it has any impact; the Medium-rated ones broadly agree at 4.3 to 6.5; and the only High from a CVSS scorer is CVE-2026-11102 (**Inferred** from [34] [38] [43]). Chromium's scale and CVSS answer different questions, and a scanner that reports only the CVSS band will rank these bugs above where Google put them (**Inferred**).

Fixed-version drift

NVD describes CVE-2026-13886 and CVE-2026-14042 as fixed "prior to 150.0.7871.47" and CVE-2026-17780 and CVE-2026-17909 as fixed "prior to 151.0.7922.72", but the release posts ship 150.0.7871.46 and 151.0.7922.71 on Linux (**Confirmed** [32] [35] [31]). A Linux fleet on .46 or .71 is patched even though a version comparison against NVD's string says otherwise (**Inferred**).

No exploitation on record

None of the ten IWA-component CVEs is in the CISA KEV catalog (version 2026.11.10, 1,779 entries) (**Confirmed** [45]). For every one, the CISA-ADP SSVC decision in NVD records exploitation "none"; only CVE-2026-11102 has technical impact "total", and only CVE-2026-17909 is marked automatable (**Confirmed** [38]). The three Controlled Frame CVEs also carry exploitation none (**Confirmed** [35] [49]; **Demonstrated** [50] for CVE-2026-87435). No Chrome Releases post attaches its "exploit exists in the wild" line to any of them; the in-the-wild line in the September post that fixed three IWA bugs is for CVE-2026-87491, a V8 bug (**Confirmed** [39]).

Part 4: offensive research, the IWA as a C2 sidecar

ChromeAlone (Praetorian, 2025)

Michael "bouncyhat" Weber of Praetorian presented "ChromeAlone: Transforming a Browser into a C2 Platform" at DEF CON 33 on 8 August 2025. The listing's abstract says the work abuses legacy and recent Chrome features to mimic a command-and-control implant, sideloads components without user interaction, and obfuscates with WebAssembly (**Reported** [71]). The ChromeAlone repository, created on 1 August 2025 under the Apache-2.0 licence, includes a component called BLOWTORCH that its README describes as a malicious Isolated Web Application using Direct Sockets for a SOCKS TCP proxy and a WebSocket bridge to its relay, plus PowerShell sideloaders for IWAs and extensions that target Windows 10 and 11. The README claims persistence that resists EDR because it is built only from Chromium features. It does not state which Chrome version was tested (**Demonstrated** [72]).

Attack of The Extensions (SpecterOps, 2026)

On 13 August 2026, SpecterOps published "Attack of The Extensions" by Andrew Gomez, an adversary simulation consultant, as a continuation of a SpecterOps post of 27 August 2025 that revisited cookie theft against Chromium's Application Bound Encryption (**Confirmed** [68]). The post introduces two tools: SilentChrome-BOF, a Beacon object file that installs Chromium extensions, IWAs and Native Messaging Hosts by editing a profile's state, and Ditto, a Mythic C2 agent that runs as a browser extension with optional IWA and native-messaging sidecars. The author calls both a vibe-coded proof of concept that has not been used on an operation (**Demonstrated** [68]). The repositories confirm the record: SilentChrome-BOF was created on 10 August 2026 under GPL-3.0 and says it targets Chrome and Edge, needs every browser process for the user-data directory closed, and needs its artifacts built beforehand; Ditto, created the same day and last pushed on 15 October 2026, describes a Windows Mythic agent for Chromium browsers with an optional signed IWA build that opens outbound Direct Sockets connections for its SOCKS bridge (**Confirmed** [69] [70]).

Why an IWA at all? Per SpecterOps, an extension cannot open raw sockets for a SOCKS proxy, so the IWA is the networking sidecar, and an extension needs a Native Messaging Host to reach Windows APIs. IWAs and Native Messaging Hosts cannot be used just by loading an unpacked extension in Developer Mode, which is why the tools tamper with the profile instead (**Demonstrated** [68]).

The research at technique level, as the post describes it:

Step	What SpecterOps shows	Grade	Source
Precondition	Code execution in the user's context on Windows already exists (a Beacon); the browser must be fully closed before the IWA install	Demonstrated	[68]
Extension install	Install state written into the profile's Secure Preferences, with the tracked-preference integrity values recomputed from a seed earlier researchers found; newer Chromium's encrypted integrity dictionary needs the Application Bound Encryption key, and the tool relies on Chromium's self-healing fallback when that dictionary is missing	Demonstrated	[68]
Allowlist evasion	Reusing another extension's public key yields the same extension ID, so a sideloaded extension can pass an enterprise allowlist keyed on extension ID	Demonstrated	[68]

Step	What SpecterOps shows	Grade	Source
IWA install	The installed app is reconstructed across several stores: Local State (switching IWA support on and registering a local key distribution component), the profile's web app database, the staged signed bundle, profile preferences for local-network and loopback exceptions, an optional icon cache, and a key distribution component that grants Direct Sockets to the bundle ID	Demonstrated	[68]
Direct Sockets grant	In the tested Chromium 148 build, the locally registered key distribution component enabled Direct Sockets without the IWA developer-mode flag, which also avoided a browser warning	Demonstrated	[68]
Local network reach	Direct Sockets alone did not allow private or loopback connections; Local Network Access exceptions had to be written, and permissions policy, entitlement and those settings must all agree	Demonstrated	[68]
C2 path	The extension forwards Mythic SOCKS frames to the IWA over a local control WebSocket, and the IWA opens outbound TCP connections with Direct Sockets	Demonstrated	[68]
Hiding	The IWA can be launched minimized, still showing a taskbar icon, with an operator page that by default imitates a Chromium updating page, or on a hidden alternate desktop, a method borrowed from ChromeAlone	Demonstrated	[68]
Native messaging	Registering a Native Messaging Host still needs a per-user registry key; the author found no file-only route in Chromium source	Demonstrated	[68]

The test conditions limit the claim. The IWA workflow was tested against Chrome 148 on Windows; the post treats Chrome and Edge together as Chromium browsers; and the author warns that the profile, database, component-registration and preference formats may change between versions (**Demonstrated** [68]). The post names no vendor disclosure, CVE or fix, and it is post-exploitation persistence, not a remote IWA exploit (**Inferred** [68]).

What the research means

Three things stand out. First, desktop Chrome's default of IWAs off is a default, not a barrier, against someone who already controls the profile: the tools switch the feature on themselves (**Demonstrated** [68]; **Inferred** for the reading). Second, the step that grants Direct Sockets, a locally registered key distribution component accepted by Chromium 148 without the developer-mode flag, touches the same component Google uses to distribute key rotations and access-control rules (**Demonstrated** [68]; **Confirmed** [19] for the component's role; **Inferred** for the connection). Third, Google's developer policy forbids patterns these IWAs resemble, such as Direct Sockets access to local network devices and pass-throughs that proxy privileged access, but the policy binds publishers who seek a place on the allowlist, not an attacker who tampers with a profile (**Confirmed** [63]; **Inferred** for the comparison).

Two web searches on 11 November 2026 found no other public offensive IWA research beyond SpecterOps and Praetorian, and no in-the-wild IWA abuse (**Inferred** from this study's searches; absence of evidence, not proof).

Part 5: the timeline

Date	Event	Grade	Source
8 Aug 2023	Google moves Chrome to weekly Stable security updates from Chrome 116 to shrink the n-day patch gap, already down to about 15 days after the biweekly move	Confirmed	[65]
8 Oct 2024	Google's post on IWA signing keys: the Web Bundle ID derives from the key, a compromised key is "a troublesome situation", rebinding only as a last resort	Confirmed	[62]
12 to 30 Dec 2024	Context: about a dozen Chrome Web Store extensions, Cyberhaven among them, receive malicious updates after developer phishing, per Sekoia	Reported	[78]
1 Aug 2025	Praetorian's ChromeAlone repository created; BLOWTORCH is an IWA with Direct Sockets	Demonstrated	[72]
8 Aug 2025	ChromeAlone presented at DEF CON 33	Reported	[71]
27 Aug 2025	SpecterOps publishes its earlier post on cookie theft and Chromium Application Bound Encryption, the predecessor of the 2026 work	Confirmed	[68]
27 Oct 2025	blink-dev announcement of the managed-installation IWA allowlist for M143	Confirmed	[21]
13 Jan 2026	Google's IWA developer policy last updated	Confirmed	[63]
10 Feb 2026	`IsolatedWebAppUserInstallationEnabled` added (ChromeOS 146, default true)	Confirmed	[12]
13 Feb 2026	Context: CVE-2026-2441, CSS use after free, fixed in Chrome 145 with an exploit in the wild	Confirmed	[53]
12 to 13 Mar 2026	Context: CVE-2026-3910 (V8) and CVE-2026-3909 (Skia), both reported by Google's Threat Analysis Group, fixed with exploits in the wild	Confirmed	[54] [55]
29 Mar 2026	Google reports CVE-2026-14042 (IWA UI spoofing)	Confirmed	[31]
31 Mar 2026	Context: CVE-2026-5281, Dawn use after free, fixed with an exploit in the wild	Confirmed	[56]
7 Apr 2026	Google reports CVE-2026-11102 (key rotation bypass) and CVE-2026-13886 (mandatory CSP bypass)	Confirmed	[25] [28] [33]
11 Apr 2026	Google reports CVE-2026-17909 (cross-origin leak) and CVE-2026-87577 (sandbox origin bypass)	Confirmed	[35] [40]
15 May 2026	Google reports CVE-2026-17780 (cross-IWA source check bypass)	Confirmed	[37]
29 May 2026	Google reports CVE-2026-87540 (warning quota exhaustion)	Confirmed	[41]

Date	Event	Grade	Source
2 Jun 2026	Chrome 149 stable fixes CVE-2026-11102	Confirmed	[25]
4 Jun 2026	NVD publishes CVE-2026-11102; CVSS 8.8 follows from NVD and CISA-ADP	Confirmed	[26]
8 Jun 2026	Context: CVE-2026-11645, V8, fixed with an exploit in the wild	Confirmed	[57]
30 Jun 2026	Chrome 150 stable fixes CVE-2026-13886 and CVE-2026-14042	Confirmed	[31]
9 Jul 2026	Google reports CVE-2026-87468 (cross-IWA navigation bypass)	Confirmed	[42]
29 Jul 2026	Chrome 151 stable fixes CVE-2026-17780, CVE-2026-17909 and Controlled Frame CVE-2026-17743	Confirmed	[35]
10 Aug 2026	SilentChrome-BOF and Ditto repositories created	Confirmed	[69] [70]
13 Aug 2026	SpecterOps publishes "Attack of The Extensions"	Confirmed (publication); Demonstrated (content)	[68]
25 Aug 2026	Chrome 152 stable adds IWA sub apps and unframed display mode	Confirmed	[22]
27 Aug 2026	Google reports CVE-2026-121172 and CVE-2026-121206	Confirmed	[43]
1 to 4 Sep 2026	Context: Volexity reports three actors delivering a Chrome and Windows zero-day chain by phishing and typosquat sites	Reported	[73] [74]
3 Sep 2026	Context: CVE-2026-85046, V8 type confusion, fixed with an exploit in the wild	Confirmed	[58]
8 Sep 2026	Chrome 153 fixes three IWA bugs and two Controlled Frame bugs; the same release fixes exploited V8 bug CVE-2026-87491, with no record linking them	Confirmed	[39]
7 Oct 2026	Context: Microsoft's Browser Vulnerability Research post on patch-gap abuse	Reported	[75]
9 Oct 2026	Last change to Chromium's IWA trust checker before this study	Confirmed	[18]
14 Oct 2026	Context: The Register reports Xbow's research Chrome chain; not in the wild, not IWA	Reported	[77]
15 Oct 2026	Last push to the Ditto repository	Confirmed	[70]
3 Nov 2026	Chrome 157 stable fixes CVE-2026-121172 and CVE-2026-121206	Confirmed	[43]
9 Nov 2026	Context: Chrome 157.0.8103.50 fixes CVE-2026-125350, XML use after free, with an exploit in the wild	Confirmed	[52]

Date	Event	Grade	Source
10 Nov 2026	Context: CISA adds CVE-2026-125350 to KEV (due 24 Nov); KEV catalog 2026.11.10 has no IWA entry	Confirmed	[45] [46]
11 Nov 2026	Chromium main: IWAs enabled by default only on ChromeOS; desktop force-install still `future_on`	Confirmed	[9] [11]

Part 6: was any of it exploited?

What the record shows

No Isolated Web App vulnerability has a documented in-the-wild exploitation record. None of the 2026 IWA or Controlled Frame CVEs is in CISA KEV, none carries Google's in-the-wild line, and CISA's SSVC entry on each record says exploitation none as of that entry's timestamp (**Demonstrated** [45]; **Confirmed** [38] [49]). Searches for IWA abuse, IWA-delivered malware or threat-actor use of IWAs returned no reports, and the TeamStarWolf Intelligence Hub feed, 6,014 rows, has no row that mentions Isolated Web Apps. That is absence of evidence, not proof (**Demonstrated** [79]).

The real Chrome zero-days of 2026

The year's exploited Chrome bugs make the contrast sharp. KEV version 2026.11.10 lists eight CVE-2026 Chromium-family browser zero-days, none in IWA code (**Demonstrated** [45]).

CVE	Component and class	Fixed in	Reported by	KEV added	Source
CVE-2026-2441	CSS, use after free; High	145.0.7632.75/76 (13 Feb)	Shaheen Fazim, 11 Feb	17 Feb	[53] [45]
CVE-2026-3910	V8, inappropriate implementation; High	146.0.7680.75/76 (12 Mar)	Google Threat Analysis Group, 10 Mar	13 Mar	[54] [45]
CVE-2026-3909	Skia, out-of-bounds write; High	146.0.7680.80 (13 Mar)	Google Threat Analysis Group, 10 Mar	13 Mar	[55] [45]
CVE-2026-5281	Dawn, use after free; High; KEV notes it needs an already-compromised renderer	146.0.7680.177/178 (31 Mar)	An anonymized reporter id, 10 Mar	1 Apr	[56] [45]
CVE-2026-11645	V8, out-of-bounds memory access; High; $55,000 reward	149.0.7827.102/.103 (8 Jun)	Reported 27 Apr	9 Jun	[57] [45]
CVE-2026-85046	V8, type confusion; High	152.0.7977.82/.83 (3 Sep)	Salvatore Gulizia, 4 Aug	4 Sep	[58] [45]
CVE-2026-87491	V8, out-of-bounds write; Medium	153.0.8010.36 (8 Sep)	Jihyeon Jeong (Compsec Lab, Seoul National University), 6 Aug	9 Sep	[39] [45]
CVE-2026-125350	XML, use after free; High; CWE-416	157.0.8103.50/.51 (9 Nov)	Arni Hardarson (Neonix Security), 12 Oct, and anonymous, 6 Nov	10 Nov, due 24 Nov	[52] [46] [47] [51]

(**Confirmed** for each row from the cited Chrome Releases post, KEV entry and CVE record.) The CVE record for CVE-2026-125350 says it allowed code execution inside the sandbox via a crafted HTML page, and CISA's SSVC entry records exploitation "active"; KEV records known ransomware use as Unknown (**Confirmed** [47] [46]). SecurityWeek counts CVE-2026-125350 as the eighth exploited Chrome zero-day of 2026 and says no details of the attacks are public (**Reported** [76]); The Hacker News and The Register say the same in their headlines as carried by the Hub feed, but the articles themselves were not opened (**Reported** [79]). One lookup that filtered KEV more narrowly returned six of the eight; both lookups agree that none is an IWA bug (**Confirmed** [45]).

The September cluster is the best documented. Volexity reports that CVE-2026-85046 and CVE-2026-87491 were chained with Windows CVE-2026-85880 in phishing campaigns on 1 and 2 September 2026, by an actor it tracks as UTA0560 against NGOs and by JungleBamboo, which it equates with APT31, and that the Chrome fix was public upstream before a Chrome release, a patch gap (**Reported** [73]). A second Volexity post reports a third actor, UTA0565, using typosquat sites with a hidden iframe to deliver the same chain on 3 and 4 September against Asian government and NGO targets (**Reported** [74]). Microsoft's Browser Vulnerability Research team says it confirmed active exploitation of a V8 remote code execution bug on 1 September and of a V8 sandbox escape on 3 September, and that Edge shipped fixes in 152.0.4191.62 and .66 before Chrome's 8 September update; it presents AI-accelerated patch-gap abuse as an assessment and names no CVE ids (**Reported** [75]). None of these reports mentions IWAs (checked in each report; the reports themselves are **Reported** [73] [74] [75]). The 8 September Chrome release that fixed CVE-2026-87491 also fixed Controlled Frame bugs CVE-2026-87513 and CVE-2026-87435, but they share a release and nothing more; no record links them (**Confirmed** [39]).

Research chains are not exploitation either. The Register reports that Xbow's six-day Chrome chain, through V8 Maglev, WebP and Crashpad, earned a $250,000 bounty as a research demonstration, not an attack, and did not involve IWAs (**Reported** [77]).

Why IWA bugs are less reachable today

The exploited 2026 Chrome bugs sit in code every desktop browser runs for ordinary web pages (V8, CSS, Skia, Dawn, XML); CVE-2026-125350's record names a crafted HTML page, and CVE-2026-5281 needed an already-compromised renderer (**Confirmed** [47] [45]). An IWA bug needs an IWA on the device, and IWAs are on by default only on ChromeOS, where admin installs are limited to Google-allowlisted apps (**Confirmed** [9] [20] [59]). Several IWA CVEs are also about one IWA attacking another or spoofing its own UI, which presumes a malicious or compromised IWA already installed (**Confirmed** for the issue titles [37] [42] [41]; **Inferred** for the precondition). That is why the exposure today sits on managed ChromeOS fleets, and why the published abuse is local persistence rather than remote exploitation (**Inferred**).

Part 7: the vulnerability-management view

Prioritizing the IWA CVEs

Signal	What it says for the IWA record	Source
KEV	No entry	[45]
CISA-ADP SSVC	Exploitation none on all; technical impact total only for CVE-2026-11102; automatable only for CVE-2026-17909	[38] [26]
EPSS	0.00371 for CVE-2026-11102 on Tenable's page	[30] (Reported)
Chromium severity	Medium or Low	[25] [31] [35] [39] [43]
CVSS	4.3 to 6.5, and 8.8 for CVE-2026-11102	[26] [32] [34] [36] [38]
Exposure	IWAs on by default only on ChromeOS; desktop install policy `future_on`	[9] [11]

On these signals the IWA bugs belong in routine browser patching, not an emergency (**Inferred**). The exception worth a closer look is CVE-2026-11102 on fleets that run allowlisted IWAs, because its public issue describes a weakness in key rotation, the mechanism that protects users after a developer's key is compromised (**Confirmed** [28] [19] [62]; **Inferred** for the priority).

Where scanners and records mislead

- **Component labels.** A detection rule or report keyed on "Isolated Web Apps" misses the five CVEs labelled only "Isolated" (**Confirmed** [44] [39] [43]).
- **Fixed builds.** NVD's "prior to" strings for the Chrome 150 and 151 bugs are one build higher than the Linux build that shipped the fix (**Confirmed** [32] [35]).
- **Severity bands.** A dashboard that shows CVSS bands will put Chromium's Low bugs in Medium and CVE-2026-11102 in High (**Inferred** from [26] [34]).

Closing the patch gap

Chrome has shipped weekly Stable security updates between milestones since Chrome 116, and after the earlier move to biweekly updates the n-day patch gap had already fallen to about 15 days (**Confirmed** [65]). A downloaded update does nothing until the browser restarts. `RelaunchNotification` (Chrome 66+, ChromeOS 70+) can recommend or require a relaunch, with a default period of seven days for Chrome and four for ChromeOS, configurable through `RelaunchNotificationPeriod` (**Confirmed** [66]). `RelaunchFastIfOutdated` (Chrome and ChromeOS 137+) cuts that period to two hours once the running version is older than a configured number of days (**Confirmed** [67]). Volexity's September reports and Microsoft's October post on the September attacks describe adversaries working in the gap between an upstream fix and a release, which is the strongest argument for tight relaunch settings (**Reported** [73] [75]; **Inferred** for the argument).

For IWAs specifically, pinning adds its own gap. `pinned_version` blocks updates beyond the pinned version, `allow_downgrades` requires a pin, and the policy warns that pinning to a version that does not exist leaves the

app stuck (**Confirmed** [11]). An IWA removed from Google's allowlist keeps running but stops updating (**Confirmed** [20]). Both produce an installed app frozen below its fixes, which CVE counts will not show (**Inferred**).

Part 8: the defender view

Hardening by situation

Situation	Control	What it does	Source
ChromeOS fleet with no IWA need	`IsolatedWebAppUserInstallationEnabled` false; leave `IsolatedWebAppInstallForceList` empty	Stops user installs; no managed IWAs	[12] [11]
ChromeOS fleet running some IWAs	`DefaultDirectSocketsSetting` 2 and `DefaultControlledFrameSetting` 2, with per-app `AllowedForUrls` entries	High-trust APIs only for the apps that need them	[13] [14] [15]
Any fleet	`DefaultSubAppsWithoutPromptsSetting` left at 3 (ask) or set to 2	No silent sub-app creation	[16]
Any fleet	`DeveloperToolsAvailability` Disallowed where users do not need DevTools	Also disables IWA developer-mode installs	[17]
Windows and Mac desktops	`ExtensionSettings` and extension allow and block lists; Developer Mode for extensions disallowed	Disallowing Developer Mode stopped SpecterOps's unpacked extension from starting its service worker; ID-keyed allowlists alone can be passed by key reuse	[64] [68]
Every fleet	Current Chrome plus `RelaunchNotification` and `RelaunchFastIfOutdated`	Shortens the window between fix and running build	[66] [67]
Managed IWAs	Review every `pinned_version` and each app's allowlist status	Finds apps frozen below their fixes	[11] [20]

(**Confirmed** for each policy's behavior from the cited source; **Demonstrated** for the extension Developer Mode result [68]; **Inferred** for the pairing of control to situation.)

Detection

SpecterOps's guidance for Windows, using Sysmon with the sysmon-modular configuration (**Demonstrated** [68]):

- File creation events (Sysmon Event 11) on the browser profile's preference files, which change when an extension or IWA is installed by tampering.
- Registry events (Sysmon Events 12 and 13) on the native-messaging registry keys.
- Process creation for Chrome started with IWA launch arguments. IWA feature flags are legitimate but rarely used on desktop, so they make a cheap signal.
- Native-host process creation that carries the calling extension's ID on its command line.

Two more signals follow from the record. A minimized Chrome window showing a page that imitates a Chromium update is one of the research tools' default disguises (**Demonstrated** [68]). Outbound connections

from a Chrome process to internal or loopback addresses, which Direct Sockets needed a Local Network Access exception to make, are worth baselining on desktops where no IWA is expected (**Demonstrated** [68]; **Inferred** for the detection).

ATT&CK's detection strategies for the extension techniques are DET0092, detection of malicious or unauthorized software extensions, for T1176, and DET0044, detecting malicious browser extensions across platforms, for T1176.001 (**Confirmed** [80] [83]). Neither ATT&CK page lists ChromeOS as a platform; T1176 and T1176.001 cover Linux, Windows and macOS, so the managed ChromeOS fleet the IWA program targets sits outside ATT&CK's platform list (**Confirmed** [80] [83]).

ATT&CK mitigations that apply

Mitigation	Applies to	How it maps to IWAs	Source
M1033 Limit Software Installation	T1176, T1176.001	User-install policy, allowlists, blocklists	[80] [83]
M1038 Execution Prevention	T1176, T1176.001	Extension Developer Mode disallowed; IWA developer mode off	[80] [17] [68]
M1047 Audit	T1176, T1176.001	Inventory of force-installed IWAs and pins	[80] [11]
M1051 Update Software	T1176, T1189, T1203	Chrome milestones that carry the IWA fixes; relaunch policies	[80] [81] [66]
M1017 User Training	T1176, T1189	The UI-spoofing CVEs need a user to trust what an IWA shows	[80] [81] [34]
M1021 Restrict Web-Based Content	T1189	Blocking Controlled Frame and Direct Sockets by default	[81] [13] [14]
M1048 Application Isolation and Sandboxing	T1189, T1203	The IWA isolation headers and per-origin storage partitions	[81] [5] [19]
M1050 Exploit Protection	T1189, T1203	Browser exploit mitigations for the crafted-page bug class	[81]

(**Confirmed** for the mitigation ids on the live ATT&CK pages and in the library data [80] [81] [83]; **Inferred** for the IWA mapping in the third column.)

Part 9: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, CWE, CAPEC and D3FEND. Every id was checked on 11 November 2026 against the live ATT&CK pages or the library's data files [80] [81] [82] [83] [84] [85] [86]. Every mapping below is this study's own and is graded Inferred, while each id, name and tactic is Confirmed. Sekoia's ids for the 2024 extension campaign are Sekoia's own mapping (**Reported** [78]). The record has no adversary use of IWAs at all, so the table labels each row by what happened: research demonstrated it, a CVE describes it as a capability, or the row comes from an adjacent record (non-IWA Chrome zero-days, an extension supply-chain campaign) included for context. IWAs do not touch industrial systems in the record, and no ATT&CK for ICS technique applies.

ATT&CK Enterprise techniques

Id	Name	Tactic (v20.0)	Where it appears in the record	Status	Source
T1176.001	Browser Extensions	Persistence	SilentChrome-BOF and Ditto sideload an extension by editing profile state (13 Aug 2026); ChromeAlone sideloads extensions (Aug 2025)	Demonstrated by researchers	[68] [72] [80]
T1176	Software Extensions	Persistence	An IWA installed by reconstructing it in the profile (SpecterOps, 13 Aug 2026) and Praetorian's BLOWTORCH IWA (Aug 2025). ATT&CK has no sub-technique for IWAs; the parent is the closest fit	Demonstrated by researchers	[68] [72] [83]
T1090	Proxy	Command and Control	The IWA opens outbound TCP with Direct Sockets as a SOCKS bridge (Ditto, 2026; BLOWTORCH, 2025)	Demonstrated by researchers	[68] [70] [72]
T1071.001	Web Protocols	Command and Control	BLOWTORCH's WebSocket bridge to its relay (2025); Ditto's local control WebSocket between extension and IWA (2026)	Demonstrated by researchers	[72] [68]
T1564.003	Hidden Window	Stealth	The IWA launched minimized or on a hidden alternate desktop (SpecterOps 2026, method from ChromeAlone)	Demonstrated by researchers	[68]
T1036	Masquerading	Stealth	Operator page imitating a Chromium updating page; extension reusing another's public key to keep its ID (13 Aug 2026)	Demonstrated by researchers	[68]
T1112	Modify Registry	Defense Impairment, Persistence	Per-user registry key for the Native Messaging Host (13 Aug 2026)	Demonstrated by researchers	[68]
T1027	Obfuscated Files or Information	Stealth	ChromeAlone's abstract: obfuscation with WebAssembly (DEF CON 33, 8 Aug 2025)	Reported (conference listing)	[71]
T1203	Exploitation for Client Execution	Execution	IWA CVEs described as reached by a crafted HTML page or malicious file (CVE-2026-11102, 4 Jun 2026; CVE-2026-13886, 30 Jun; CVE-2026-87468, 8 Sep). Context: the eight exploited non-IWA Chrome zero-days of 2026	Capability for IWAs, not observed; observed only for non-IWA bugs	[26] [32] [39] [45] [81]
T1189	Drive-by Compromise	Initial Access	The delivery path for crafted-page bugs. Context: UTA0565's typosquat sites with a hidden iframe (3 to 4 Sep 2026) delivering a non-IWA chain	Capability for IWAs, not observed; reported for non-IWA bugs	[81] [74]
T1566	Phishing	Initial Access	Context: UTA0560 and JungleBamboo phishing delivering the non-IWA Chrome and Windows chain (1 to 2 Sep 2026)	Context, reported; not IWA	[73]
T1583.001	Domains	Resource Development	Context: UTA0565's typosquat sites (Sep 2026)	Context, reported; not IWA	[74]

Id	Name	Tactic (v20.0)	Where it appears in the record	Status	Source
T1566.002	Spearphishing Link	Initial Access	Context: phishing of Chrome Web Store developers from mid-November 2024 (Sekoia's mapping)	Context, reported; not IWA	[78]
T1586.003	Cloud Accounts	Resource Development	Context: developer accounts used to authorize a malicious OAuth app with publish rights (Sekoia's mapping)	Context, reported; not IWA	[78]
T1528	Steal Application Access Token	Credential Access	Context: the malicious OAuth app's publish rights (Sekoia's mapping)	Context, reported; not IWA	[78]
T1550.001	Application Access Token	Lateral Movement	Context: the token used to publish malicious extension updates (Sekoia's mapping)	Context, reported; not IWA	[78]
T1539	Steal Web Session Cookie	Credential Access	Context: the malicious extension updates harvested session cookies and tokens, 12 to 30 Dec 2024 (Sekoia's mapping)	Context, reported; not IWA	[78]
T1195.002	Compromise Software Supply Chain	Initial Access	Context: malicious updates pushed to users of legitimate extensions (Dec 2024); this study's reading, not Sekoia's list	Context, reported event; Inferred mapping	[78]

Considered and not bound: T1185 Browser Session Hijacking describes what Controlled Frame's explainer warns an embedding IWA could do, but no record shows it done, by researchers or anyone else, so it is left out (**Confirmed** [7]; Inferred for the judgment). T1068 Exploitation for Privilege Escalation is left out because the verified record names the Windows CVE in the September chain but not its class.

ATT&CK groups, software and campaigns

Object	Id	Role in this record	Status	Source
Mythic	S0699	Ditto is an agent for the Mythic C2 framework	Research tooling, Demonstrated; no adversary use of Ditto	[68] [70] [86]
Cobalt Strike	S0154	SilentChrome-BOF is a Beacon object file and the technique assumes a running Beacon; Beacon is Cobalt Strike's agent	Research tooling, Demonstrated; the Cobalt Strike link is Inferred from the term Beacon	[68] [69] [86]
ZIRCONIUM	G0128	Volexity names JungleBamboo, which it equates with APT31, among the users of the September 2026 Chrome and Windows chain; ATT&CK lists APT31 as an alias of G0128	Context only: a non-IWA campaign, Reported	[73] [86]

No ATT&CK campaign object covers IWA abuse or the 2026 Chrome zero-days (**Confirmed** [86]). UTA0560, UTA0565 and the JungleBamboo name have no ATT&CK object of their own (**Confirmed** [86]). For the wider record on APT31 see Threat Actors: China.

CWE and CAPEC

Weakness	Name	Who assigns it	CVEs	CAPEC in the library	Source
CWE-474	Use of Function with Inconsistent Implementations	CISA-ADP (NVD: noinfo)	CVE-2026-11102	None: the library's `cwe.jsonl` relates no CAPEC entry	[26] [85]
CWE-693	Protection Mechanism Failure	CISA-ADP	CVE-2026-13886	Related entries exist, none specific to CSP bypass, so none is bound	[32] [85]
CWE-451	User Interface (UI) Misrepresentation of Critical Information	CISA-ADP	CVE-2026-14042, CVE-2026-121206	CAPEC-173 Action Spoofing and CAPEC-154 Resource Location Spoofing, both related to CWE-451 in the library (Inferred pairing)	[34] [43] [85]
CWE-284	Improper Access Control	CISA-ADP	CVE-2026-17780	Related entries exist, none specific to navigation checks, so none is bound	[36] [85]
CWE-20	Improper Input Validation	CISA-ADP	CVE-2026-17909	Too broad to bind a single entry	[38] [85]
CWE-863	Incorrect Authorization	CISA-ADP	CVE-2026-87577, -87540, -87468, -121172	None: the library relates no CAPEC entry	[39] [43] [85]

Two more CAPEC entries apply through the techniques above: CAPEC-698 Install Malicious Extension, which the library maps to T1176, and CAPEC-203 Manipulate Registry Information, which it maps to T1112 (**Confirmed** for the library data [85]; Inferred for the pairing with the research). For the context rows, the library maps CAPEC-21 Exploitation of Trusted Identifiers and CAPEC-31 Accessing/Intercepting/Modifying HTTP Cookies to T1539 (**Confirmed** [85]). The library has no generated CWE pages; the CWE Reference and CAPEC Reference cover the classes.

D3FEND countermeasures

Countermeasure	Id	Library mappings to this study's techniques	IWA control it matches	Source
Software Update	D3-SU	T1176, T1195.002	Chrome milestones carrying the IWA fixes; relaunch policies	[82] [84] [66]
Software Inventory	D3-SWI	T1176, T1195.002	Inventory of force-installed IWAs, pins and allowlist status	[84] [11]
Asset Vulnerability Enumeration	D3-AVE	T1176, T1195.002	Matching installed Chrome builds to the per-platform fixed builds	[84] [43]
Executable Allowlisting	D3-EAL	Not mapped to these techniques	Google's IWA allowlist and the extension allowlist policies are the policy analogues (Inferred pairing)	[84] [20] [64]
Application Configuration Hardening	D3-ACH	Not mapped to these techniques	`IsolatedWebAppUserInstallationEnabled`, `DefaultDirectSocketsSetting`, `DefaultControlledFrameSetting` (Inferred pairing)	[84] [12] [13] [14]
System Configuration Permissions	D3-SCP	T1112, T1564.003	Restricting who can write the native-messaging registry keys (Inferred pairing)	[84] [68]
File Integrity Monitoring	D3-FIM	T1071.001, T1564.003, T1566.002	Watching the profile preference files SpecterOps names (Inferred pairing)	[84] [68]
Outbound Traffic Filtering	D3-OTF	T1071.001	Egress control for a browser acting as a SOCKS bridge (Inferred pairing)	[84] [68]
Relay Pattern Analysis	D3-RPA	T1071.001	Spotting a browser process relaying traffic (Inferred pairing)	[84] [72]
URL Analysis	D3-UA	T1189, T1566.002	Crafted-page delivery of the bug class	[84] [81]
URL Reputation Analysis	D3-URA	T1189, T1566.002	Typosquat delivery in the September context	[84] [74]
Homoglyph Detection	D3-HD	T1189, T1566.002	Typosquat domains in the September context	[84] [74]
Content Filtering	D3-CF	T1071.001, T1564.003, T1566.002	Filtering hostile content before it reaches the browser	[82] [84]

The live D3FEND API resolves D3-SU, D3-EAL, D3-ACH, D3-UA and D3-CF, and each has a library page (**Confirmed** [82] for the API entries; [84] for the library pages). The technique column is the library's `technique_to_d3fend.jsonl` (**Confirmed** [84]). Hardware-based Process Isolation (D3-HBPI) has a library page but is not mapped to this study's techniques in `technique_to_d3fend.jsonl`, so it is left out (**Confirmed** [84]).

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/chrome-isolated-web-apps-2026.json, listed on the Navigator layers page. It is pinned to ATT&CK v20 and scores each technique by what the record shows: 50 where researchers demonstrated it against Chromium's extension and IWA surface, 25 for a capability the IWA CVE records describe that no one was observed using, and 10 for context rows drawn from adjacent records (non-IWA Chrome zero-days and the 2024 extension campaign) and for the WebAssembly obfuscation known only from a conference listing. No technique carries a score for adversary use of IWAs, because none was observed. Browser Session Hijacking and Exploitation for Privilege Escalation are left out. Each entry's comment names the source numbers above.

Cross-cutting themes

- **Signed code moves trust; it does not remove it.** IWAs take the live web server out of the trust chain and put the signing key, the update manifest host and Google's allowlist and key distribution in its place (**Inferred** from [2] [19] [20]). The SolarWinds SUNBURST and Stuxnet studies record what happens when signing and update machinery is abused (sources and grades there), and the eMudhra study records a certificate authority compromise (sources and grades there). The most severe-scored IWA bug of 2026 sits in key rotation (**Confirmed** [28]).
- **High-trust APIs make the app the attack surface.** Direct Sockets and Controlled Frame are gated precisely because they are dangerous on the open web, and the only public abuse uses Direct Sockets in ways the developer policy forbids for publishers (**Confirmed** [1] [63]; **Demonstrated** [68] [72]; **Inferred** for the comparison).
- **Off by default is not the same as absent.** Desktop Chrome ships IWAs disabled, yet the research tools enable them in the profile once they have code execution (**Demonstrated** [68]). Defaults protect against the drive-by web, not against a local attacker (**Inferred**).
- **Browsers are now persistence platforms.** Extensions, IWAs and native messaging hosts together give an implant storage, networking and a route to the operating system, all inside the browser process itself (**Demonstrated** [68] [72]; **Inferred** for the characterization). The npm supply chain and Hugging Face supply chain studies show the parallel problem in developer ecosystems, and the 2024 extension campaign shows it in the Chrome Web Store (**Reported** [78]).
- **Labels shape what defenders see.** A component renamed from "Isolated Web Apps" to "Isolated" halves what a keyword search finds, and two severity scales disagree on the same bug (**Confirmed** [44] [26]).
- **Exploitation evidence should drive urgency.** The year's eight exploited Chrome bugs were all outside IWA code; KEV and vendor in-the-wild statements, not the newest feature's headline, are what tell a defender to move tonight (**Confirmed** [45]; **Inferred** for the advice). See Log4Shell for the opposite case, a bug where exploitation evidence arrived within hours (sources and grades there).
- **Patch gaps are being worked.** Volexity and Microsoft describe adversaries using the window between an upstream fix and a release (**Reported** [73] [75]). The AI Threats 2026 study covers the wider claims about AI and patch volume (sources and grades there).

What is overstated and what is understated

- **Overstated: "Chrome IWA hack" or "IWA zero-day".** No IWA or Controlled Frame CVE is in KEV, every one was found by Google, Chromium rated them Medium or Low, and SSVC records exploitation none (**Confirmed** [45] [38] [49]; **Inferred** for the reading).
- **Overstated: "arbitrary code execution" for CVE-2026-11102.** The phrase comes from the NVD description, but the same description says the code runs inside a sandbox; Chromium rated it Medium, and its public issue describes a key-rotation bypass (**Confirmed** [26] [28]).
- **Overstated: desktop exposure.** Desktop IWA policy install is only `future_on`, IWAs are off by default outside ChromeOS, and desktop use needs the developer-mode flag or profile tampering (**Confirmed** [9] [11] [20]; **Demonstrated** [68]).
- **Overstated: the research tools as a remote threat.** SpecterOps's tools need prior code execution as the user on Windows and a fully closed browser (**Demonstrated** [68]; **Confirmed** [69]); ChromeAlone's PowerShell sideloaders imply local execution too (**Inferred** [72]).
- **Understated: the count.** Ten IWA-component CVEs, not the five a keyword search finds, plus three in Controlled Frame (**Confirmed** [44] [39] [43]; **Inferred** for the union).
- **Understated: ChromeOS defaults.** User IWA installs default to permitted from ChromeOS 146, and Direct Sockets and Controlled Frame default to allowed for IWA origins (**Confirmed** [12] [13] [14]).
- **Understated: frozen apps.** `pinned_version` and allowlist removal both leave an installed IWA below its fixes, and no CVE count shows it (**Confirmed** [11] [20]; **Inferred** for the risk).
- **Understated: the local trust path.** In the tested Chromium 148 build, a locally registered key distribution component granted Direct Sockets with no developer-mode flag and no warning, and no disclosure or fix is named for it (**Demonstrated** [68]).

Sources

All sources were opened on 11 November 2026. Grades apply to the source as used here. Chromium source and policy files were read through the GitHub mirror of chromium/chromium at main.

#	Source	URL	Opened	Grade
1	Chrome for Developers, Isolated Web Apps introduction	developer.chrome.com/docs/iwa/introduction	2026-11-11	Confirmed
2	WICG, Isolated Web Apps explainer	github.com/WICG/isolated-web-apps/blob/main/README.md	2026-11-11	Confirmed
3	WICG, Signed Web Bundle integrity block and signatures explainer	github.com/WICG/webpackage/.../integrity-signature.md	2026-11-11	Confirmed
4	WICG, the `isolated-app` scheme	github.com/WICG/isolated-web-apps/blob/main/Scheme.md	2026-11-11	Confirmed
5	ChromeOS.dev, Isolated Web Apps	chromeos.dev/en/web/isolated-web-apps	2026-11-11	Confirmed
6	WICG, IWA permissions proposal	github.com/WICG/isolated-web-apps/blob/main/Permissions.md	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
7	WICG, Controlled Frame explainer	github.com/WICG/controlled-frame/blob/main/README.md	2026-11-11	Confirmed
8	WICG, Direct Sockets explainer	github.com/WICG/direct-sockets/blob/main/docs/explainer.md	2026-11-11	Confirmed
9	Chromium, `content/public/common/content_features.cc`	github.com/chromium/chromium/.../content_features.cc	2026-11-11	Confirmed
10	Chromium, `chrome/common/chrome_features.cc`	github.com/chromium/chromium/.../chrome_features.cc	2026-11-11	Confirmed
11	Chromium policy definition, `IsolatedWebAppInstallForceList` (also read at raw.githubusercontent.com)	github.com/chromium/chromium/.../IsolatedWebAppInstallForceList.yaml	2026-11-11	Confirmed
12	Chromium policy definition, `IsolatedWebAppUserInstallationEnabled`	github.com/chromium/chromium/.../IsolatedWebAppUserInstallationEnabled.yaml	2026-11-11	Confirmed
13	Chromium policy definition, `DefaultDirectSocketsSetting` and the Direct Sockets URL lists	github.com/chromium/chromium/.../DefaultDirectSocketsSetting.yaml	2026-11-11	Confirmed
14	Chromium policy definition, `DefaultControlledFrameSetting`	github.com/chromium/chromium/.../DefaultControlledFrameSetting.yaml	2026-11-11	Confirmed
15	Chromium policy definition, `ControlledFrameAllowedForUrls`	raw.githubusercontent.com/chromium/chromium/.../ControlledFrameAllowedForUrls.yaml	2026-11-11	Confirmed
16	Chromium policy definition, `DefaultSubAppsWithoutPromptsSetting`	github.com/chromium/chromium/.../DefaultSubAppsWithoutPromptsSetting.yaml	2026-11-11	Confirmed
17	Chromium, `isolated_web_app_features.cc`	github.com/chromium/chromium/.../isolated_web_app_features.cc	2026-11-11	Confirmed
18	Chromium, `isolated_web_app_trust_checker.cc` (last changed 9 Oct 2026)	github.com/chromium/chromium/.../isolated_web_app_trust_checker.cc	2026-11-11	Confirmed
19	Chromium, Isolated Web Apps README	github.com/chromium/chromium/.../isolated_web_apps/README.md	2026-11-11	Confirmed
20	Chrome for Developers, IWA allowlist	developer.chrome.com/docs/iwa/allowlist	2026-11-11	Confirmed
21	blink-dev, PSA: Isolated Web Apps Allowlist for Managed Installations, 27 Oct 2025	groups.google.com/a/chromium.org/g/blink-dev/c/iTCPaBw6HxU	2026-11-11	Confirmed
22	Chrome for Developers, Chrome 152 release notes (stable 25 Aug 2026)	developer.chrome.com/release-notes/152	2026-11-11	Confirmed
23	chromestatus, features API, query "isolated web app"	chromestatus.com/api/v0/features?q=isolated%20web%20app	2026-11-11	Confirmed
24	Chromium policy definition, `IsolatedModeSettings`	github.com/chromium/chromium/.../IsolatedModeSettings.yaml	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
25	Chrome Releases, Stable Channel Update for Desktop (Chrome 149), 2 Jun 2026	chromereleases.googleblog.com/2026/06/stable-channel-update-for-desktop.html	2026-11-11	Confirmed
26	NVD, CVE-2026-11102	nvd.nist.gov/vuln/detail/CVE-2026-11102	2026-11-11	Confirmed
27	NVD CVE API, CVE-2026-11102	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-11102	2026-11-11	Confirmed
28	Chromium issue 500468338	issues.chromium.org/issues/500468338	2026-11-11	Confirmed
29	Red Hat Bugzilla 2485218, CVE-2026-11102	bugzilla.redhat.com/show_bug.cgi?id=2485218	2026-11-11	Reported
30	Tenable, CVE-2026-11102	tenable.com/cve/CVE-2026-11102	2026-11-11	Reported
31	Chrome Releases, Stable Channel Update for Desktop (Chrome 150), 30 Jun 2026	chromereleases.googleblog.com/2026/06/stable-channel-update-for-desktop_0175352312.html	2026-11-11	Confirmed
32	NVD, CVE-2026-13886	nvd.nist.gov/vuln/detail/CVE-2026-13886	2026-11-11	Confirmed
33	Chromium issue 500475136	issues.chromium.org/issues/500475136	2026-11-11	Confirmed
34	NVD, CVE-2026-14042	nvd.nist.gov/vuln/detail/CVE-2026-14042	2026-11-11	Confirmed
35	Chrome Releases, Stable Channel Update for Desktop (Chrome 151), 29 Jul 2026	chromereleases.googleblog.com/2026/07/stable-channel-update-for-desktop_0887107924.html	2026-11-11	Confirmed
36	NVD, CVE-2026-17780	nvd.nist.gov/vuln/detail/CVE-2026-17780	2026-11-11	Confirmed
37	Chromium issue 513485951	issues.chromium.org/issues/513485951	2026-11-11	Confirmed
38	NVD, CVE-2026-17909	nvd.nist.gov/vuln/detail/CVE-2026-17909	2026-11-11	Confirmed
39	Chrome Releases, Stable Channel Update for Desktop (Chrome 153), 8 Sep 2026	chromereleases.googleblog.com/2026/09/stable-channel-update-for-desktop_0808145027.html	2026-11-11	Confirmed
40	Chromium issue 501700023	issues.chromium.org/issues/501700023	2026-11-11	Confirmed
41	Chromium issue 517721914	issues.chromium.org/issues/517721914	2026-11-11	Confirmed
42	Chromium issue 532931962	issues.chromium.org/issues/532931962	2026-11-11	Confirmed
43	Chrome Releases, Stable Channel Update for Desktop (Chrome 157), 3 Nov 2026	chromereleases.googleblog.com/2026/11/stable-channel-update-for-desktop.html	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
44	NVD CVE API, exact keyword search "Isolated Web Apps"	services.nvd.nist.gov/rest/json/cves/2.0?keywordSearch=Isolated%20Web%20Apps&keywordExactMatch	2026-11-11	Confirmed
45	CISA, Known Exploited Vulnerabilities catalog JSON feed (catalogVersion 2026.11.10)	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
46	CISA, KEV catalog entry for CVE-2026-125350	cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-125350	2026-11-11	Confirmed
47	CVE List (cvelistV5), CVE-2026-125350	github.com/CVEProject/cvelistV5/.../CVE-2026-125350.json	2026-11-11	Confirmed
48	CVE List (cvelistV5), CVE-2026-11102	github.com/CVEProject/cvelistV5/.../CVE-2026-11102.json	2026-11-11	Confirmed
49	CVE List (cvelistV5), CVE-2026-87513	github.com/CVEProject/cvelistV5/.../CVE-2026-87513.json	2026-11-11	Confirmed
50	CVE List (cvelistV5) repository, code search for "Isolated Web App" and "Controlled Frame"	github.com/CVEProject/cvelistV5	2026-11-11	Demonstrated (search result)
51	NVD, CVE-2026-125350	nvd.nist.gov/vuln/detail/CVE-2026-125350	2026-11-11	Confirmed
52	Chrome Releases, Stable Channel Update for Desktop (157.0.8103.50), 9 Nov 2026	chromereleases.googleblog.com/2026/11/stable-channel-update-for-desktop_018223192.html	2026-11-11	Confirmed
53	Chrome Releases, Stable Channel Update for Desktop, 13 Feb 2026	chromereleases.googleblog.com/2026/02/stable-channel-update-for-desktop_13.html	2026-11-11	Confirmed
54	Chrome Releases, Stable Channel Update for Desktop, 12 Mar 2026	chromereleases.googleblog.com/2026/03/stable-channel-update-for-desktop_12.html	2026-11-11	Confirmed
55	Chrome Releases, Stable Channel Update for Desktop, 13 Mar 2026	chromereleases.googleblog.com/2026/03/stable-channel-update-for-desktop_13.html	2026-11-11	Confirmed
56	Chrome Releases, Stable Channel Update for Desktop, 31 Mar 2026	chromereleases.googleblog.com/2026/03/stable-channel-update-for-desktop_31.html	2026-11-11	Confirmed
57	Chrome Releases, Stable Channel Update for Desktop, 8 Jun 2026	chromereleases.googleblog.com/2026/06/stable-channel-update-for-desktop_0153744567.html	2026-11-11	Confirmed
58	Chrome Releases, Stable Channel Update for Desktop, 3 Sep 2026	chromereleases.googleblog.com/2026/09/stable-channel-update-for-desktop_01882797386.html	2026-11-11	Confirmed
59	Google Chrome Enterprise help, Automatically install web apps and Isolated Web Apps	support.google.com/chrome/a/answer/9367354	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
60	Google Chrome Enterprise and Education, previous release notes	support.google.com/chrome/a/answer/10314655	2026-11-11	Confirmed (positional reading of targets Inferred)
61	Chrome for Developers, IWA version management	developer.chrome.com/docs/iwa/version-management	2026-11-11	Confirmed
62	ChromeOS.dev, Managing Isolated Web Apps signing keys, 8 Oct 2024	chromeos.dev/en/posts/managing-isolated-web-apps-signing-keys	2026-11-11	Confirmed
63	Chrome for Developers, IWA developer policy (last updated 13 Jan 2026)	developer.chrome.com/docs/iwa/developer-policy	2026-11-11	Confirmed
64	Chromium policy definitions, `ExtensionSettings` and `ExtensionInstallAllowlist`	raw.githubusercontent.com/chromium/chromium/.../ExtensionSettings.yaml	2026-11-11	Confirmed
65	Google Security Blog, An update on Chrome security updates, 8 Aug 2023	security.googleblog.com/2023/08/an-update-on-chrome-security-updates.html	2026-11-11	Confirmed
66	Chromium policy definition, `RelaunchNotification`	raw.githubusercontent.com/chromium/chromium/.../RelaunchNotification.yaml	2026-11-11	Confirmed
67	Chromium policy definition, `RelaunchFastIfOutdated`	raw.githubusercontent.com/chromium/chromium/.../RelaunchFastIfOutdated.yaml	2026-11-11	Confirmed
68	SpecterOps, "Attack of The Extensions" by Andrew Gomez, 13 Aug 2026	specterops.io/blog/2026/08/13/chromium-extension-c2-persistence/	2026-11-11	Demonstrated (publication details Confirmed)
69	SilentChrome-BOF repository	github.com/KingOfTheNOPs/SilentChrome-BOF	2026-11-11	Confirmed (repository record)
70	Ditto repository	github.com/KingOfTheNOPs/Ditto	2026-11-11	Confirmed (repository record)
71	InfoCon DB, DEF CON 33 listing, "ChromeAlone: Transforming a Browser into a C2 Platform", 8 Aug 2025	infocondb.org/con/def-con/def-con-33/chromealone-transforming-a-browser-into-a-c2-platform	2026-11-11	Reported
72	Praetorian, ChromeAlone repository	github.com/praetorian-inc/ChromeAlone	2026-11-11	Demonstrated
73	Volexity, Mind the (Patch) Gap: multiple Chinese threat actors chain 0-day exploits in Chrome and Windows, 9 Sep 2026	volexity.com/blog/2026/09/09/mind-the-patch-gap-...	2026-11-11	Reported
74	Volexity, Mind the Patch Gap part 2: fake websites used to deploy Chrome and Windows 0-day exploits, 21 Sep 2026	volexity.com/blog/2026/09/21/mind-the-patch-gap-part-2-...	2026-11-11	Reported
75	Microsoft Browser Vulnerability Research, AI and the rise of patch-gap abuse, 7 Oct 2026	microsoftedge.github.io/edgevr/posts/AI-And-Rise-Patch-Gap-Abuse/	2026-11-11	Reported
76	SecurityWeek, Chrome update patches exploited XML zero-day, eighth this year, 10 Nov 2026	securityweek.com/chrome-update-patches-exploited-xml-zero-day-eighth-this-year/	2026-11-11	Reported

#	Source	URL	Opened	Grade
77	The Register, Xbow's six-day Chrome exploit chain, 14 Oct 2026	theregister.com/security/2026/10/14/...	2026-11-11	Reported
78	Sekoia, Targeted supply chain attack against Chrome browser extensions (January 2025)	sekoia.com/blog/targeted-supply-chain-attack-against-chrome-browser-extensions	2026-11-11	Reported
79	TeamStarWolf Intelligence Hub, `feed.json` (6,014 rows; used as an index, and for the trade-press headlines in Part 6)	teamstarwolf.github.io/intelligence-hub/data/feed.json	2026-11-11	Demonstrated (search result); headlines Reported
80	MITRE ATT&CK v20, T1176.001 Software Extensions: Browser Extensions	attack.mitre.org/techniques/T1176/001/	2026-11-11	Confirmed
81	MITRE ATT&CK v20, T1203 Exploitation for Client Execution	attack.mitre.org/techniques/T1203/	2026-11-11	Confirmed
82	MITRE D3FEND API, technique entries for SoftwareUpdate, ExecutableAllowlisting, ApplicationConfigurationHardening, URLAnalysis and ContentFiltering	d3f:SoftwareUpdate, d3f:ExecutableAllowlisting, d3f:ApplicationConfigurationHardening, d3f:URLAnalysis, d3f:ContentFiltering	2026-11-11	Confirmed
83	TeamStarWolf library data, `data/attack/technique_profiles.jsonl` and the `mitre/techniques/` pages	github.com/TeamStarWolf/TeamStarWolf/tree/main/mitre/techniques	2026-11-11	Confirmed
84	TeamStarWolf library data, `data/attack/technique_to_d3fend.jsonl` and `data/attack/d3fend_countermeasures.jsonl`, and the `mitre/d3fend/` pages	github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/technique_to_d3fend.jsonl	2026-11-11	Confirmed
85	TeamStarWolf library data, `data/weaknesses/cwe.jsonl` and `data/weaknesses/capec.jsonl`	github.com/TeamStarWolf/TeamStarWolf/blob/main/data/weaknesses/cwe.jsonl	2026-11-11	Confirmed
86	TeamStarWolf library data, `data/attack/groups.jsonl`, `data/attack/software.jsonl` and `data/attack/campaigns.jsonl`	github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/groups.jsonl	2026-11-11	Confirmed

Could not be opened: Chromium issues 497558336, 501693236, 553270515 and 553289241 (restricted), VulDB's entry for CVE-2026-11102, the Chrome Enterprise policy list pages (rendered by script; the Chromium policy definitions were read instead), the Chrome Enterprise policy page for `ExtensionDeveloperModeSettings` that SpecterOps links, and The Hacker News and The Register articles of 10 November 2026 (their headlines were read from the Hub feed [79]). The Chrome version ChromeAlone was tested against is not stated in its README. The stable date of Chrome 143 was not checked.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Browser Security Reference, Endpoint Security Reference, Enterprise Security Controls, Zero Trust Reference
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Threat Actors, Malware Families, Notable Incidents: no actor or malware family is attributed to any use of Isolated Web Apps; ZIRCONIUM appears only as context for a non-IWA Chrome campaign
- Vulnerability Prioritization Reference, Vulnerability Management Reference
- Red Team Reference, Detection Rules Reference, Living off the Land Detection, Supply Chain Security Reference
- Related case studies: AI Threats 2026, eMudhra Certificate Authority Compromise, SolarWinds SUNBURST, Stuxnet, Log4Shell, npm Supply Chain Attacks, Hugging Face Supply Chain, Threat Actors: China
- Techniques: T1176.001 Browser Extensions, T1176 Software Extensions, T1090 Proxy, T1071.001 Web Protocols, T1564.003 Hidden Window, T1036 Masquerading, T1112 Modify Registry, T1027 Obfuscated Files or Information, T1203 Exploitation for Client Execution, T1189 Drive-by Compromise, T1539 Steal Web Session Cookie
- Groups and software: G0128 ZIRCONIUM (context only), S0699 Mythic, S0154 Cobalt Strike
- CAPEC: CAPEC-698 Install Malicious Extension, CAPEC-203 Manipulate Registry Information, CAPEC-173 Action Spoofing, CAPEC-154 Resource Location Spoofing
- D3FEND: Software Update, Software Inventory, Executable Allowlisting, Application Configuration Hardening, File Integrity Monitoring, Outbound Traffic Filtering
- Navigator layers, including this study's layer, chrome-isolated-web-apps-2026.json
- All case studies